PRACTICAL LABORATORY ASSIGNMENT

Full Name	OSAWARU PRAISE
Registration Number	C11/26/CGRCE/17564
Date Submitted	8th November 2026
Course	GRC 103 Week 3 Lab B
Tool Used	Kali Linux & Ubuntu

2 Measure Risk and Remove Exposure

Step 4 Collect baseline evidence from Kali

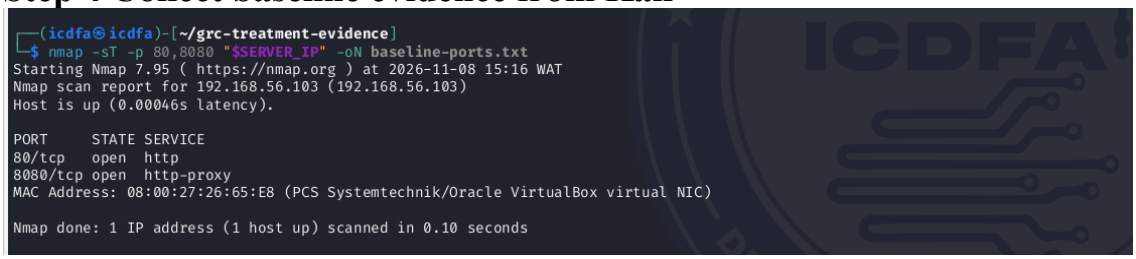


Figure 1 NMAP SERVERIP Output



Figure 2 Curl baseline-web output

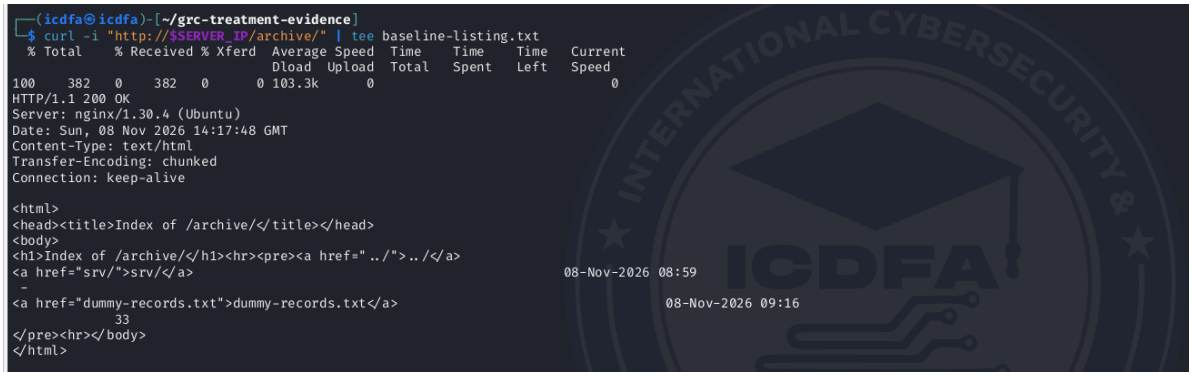


Figure 3 Curl baseline-listing output

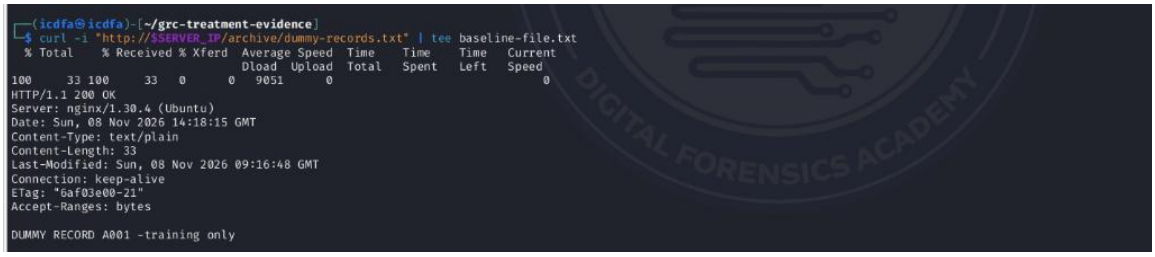


Figure 4 Curl Baseline-file output



Figure 5 Curl Baseline-legacy output

Step 5: Baseline Risk Register

ID	Risk	L	I	Score	Band
R1	Unnecessary legacy service	4	3	12	High
R2	Exposed archive	5	4	20	Critical
R3	Unauthorised network access	4	4	16	High
R4	Loss of portal content	3	4	12	High

R1: Unnecessary legacy service

- **Asset:** the server and its attack surface
- **Threat event:** an unauthorised person reaches an unused, unmonitored endpoint
- **Weakness:** port 8080 listens on 0.0.0.0, with no authentication and no owner
- **Impact:** a larger attack surface and an unmanaged service
- **Evidence:** baseline-ports.txt, baseline-legacy.txt, Ubuntu step4-ss-baseline.txt

R2: Exposed archive

- **Asset:** archive records (dummy data, but treat them as business records)
- **Threat event:** unauthorised disclosure through the web server
- **Weakness:** the archive sits inside the web root, directory listing is on, and the file is directly readable
- **Impact:** a confidentiality breach if the content were real

- **Evidence:** baseline-listing.txt, baseline-file.txt

R3: Unauthorised network access

- **Asset:** the web server and its services
- **Threat event:** any host on the network connects to any listening service
- **Weakness:** no host firewall, so UFW is inactive and every listening port is reachable
- **Impact:** exposure and abuse of all services
- **Evidence:** baseline-ports.txt, Ubuntu step4-ufw-baseline.txt

R4: Loss of portal content

- **Asset:** the portal's index.html content
- **Threat event:** deletion, corruption or failure with no way to restore
- **Weakness:** no backup of the web content and no tested recovery
- **Impact:** an outage of unknown length, because there is no recovery procedure
- **Evidence:** this one needs a quick capture, because the "absence of a backup" has to be shown.

Step 6 Apply avoidance to the legacy workflow

Item	What to write
Proposed change	Retire the unused legacy endpoint (port 8080) and retain the approved portal (port 80)
Business impact	The endpoint is unused, so none is expected, and the portal on port 80 is unaffected
Approval role	service owner or IT manager
Test plan	Confirm 8080 is closed and port 80 still works, from Kali
Rollback	sudo systemctl enable --now grc-legacy, then confirm 8080 is back



Figure 6 avoidance final ports output

- **Why it works:** with no process listening on 8080, nobody can reach that service. Removing it eliminates the whole risk of the legacy workflow (R1) instead of reducing it.
- **What remains:** nginx on port 80 is still reachable by any host, the archive is still published (R2), there is no firewall (R3) and there is no backup (R4).
- **Avoidance** removes an activity or exposure, and doesn't make the rest of the system safe.

Step 7 Remove archive publication



Figure 7 Remove archive publication output

Why disabling listing alone would nor prevent direct-file access

- autoindex off only stops nginx from showing a *list* of files in a directory.
- If the file is still inside the web root, anyone who knows or guesses the URL can still request it directly, and nginx will serve it.
- So the control that fixes it is **moving the files out of the web root** (nothing is published) plus the **explicit deny** (the old URL is blocked even if something is placed there again).
- Evidence: the baseline baseline-file.txt returned 200 with the record text, and archive-file.txt now returns 403.
- Remaining limits: the web service is still reachable by any host (R3) and there is still no backup (R4).

Step 8 Restrict network access with UFW



Figure 8 Blocked Source test output

- **Control:** default-deny incoming, with one allow rule for the approved source on port 80.
- **Effect on R3:** only the approved host can reach the web service now, so the likelihood of unauthorised network access falls. The impact doesn't change.
- **Evidence:** approved source got 200, an unapproved source timed out, and the rules are recorded in the UFW output.
- **Limits:** this does not encrypt traffic (HTTP is still plain), it doesn't stop an attacker using the approved Kali address, and it doesn't fix R4.

The monitoring table

Check	Owner (role)	Frequency	Threshold	Escalation
Portal availability	Service owner / system administrator	Every 5 minutes (automated)	HTTP 200 on /public/; alert after 2 consecutive failures	Notify admin immediately; escalate to IT manager if down more than 30 minutes
Unexpected open ports	System administrator	Daily scan from an approved host	Only port 80 open; any other port is a finding	Same-day investigation; treat as an incident if the port can't be explained
Recovery-test success	System administrator	Monthly restore test	Hash comparison OK and the portal returns 200 within the agreed recovery time	Failed test reported to IT manager within 1 business day; fix before the next change

Drift: retired service	System administrator	Daily	grc-legacy is disabled and inactive; no listener on 8080	Immediate re-disable and a change-control review of who re-enabled it

Step 11 Model transfer and acceptance

	Local-only backup (what you built in Step 10)	**Fictional managed-backup offer**
First-year cost	$0 extra	$120 + (12 × $20) = **$360**
Copy location	Same host	Provider-side (off-host)
Protects against	Accidental deletion or corruption	Same, plus loss of the host
Does not protect against	Host loss, disk failure, compromise of the host	Provider failure, misconfigured jobs, anything you don't test
Tested in this lab	Yes (restore passed, X seconds)	**No**, a fictional offer, so nothing is measured

Step 12 Compare costs and remaining risk

	Local-only backup (what you built in Step 10)	**Fictional managed-backup offer**
First-year cost	$0 extra	$120 + (12 × $20) = **$360**
Copy location	Same host	Provider-side (off-host)
Protects against	Accidental deletion or corruption	Same, plus loss of the host
Does not protect against	Host loss, disk failure, compromise of the host	Provider failure, misconfigured jobs, anything you don't test
Tested in this lab	Yes (restore passed, X seconds)	**No**, a fictional offer, so nothing is measured